

UNIVERSIDAD NACIONAL

Escuela de Informática

Curso: Administración de Bases de Datos

Proyecto Integrador (parte 1)

Desarrollo de una Aplicación Web para la Evaluación del Riesgo en la Administración de Bases de Datos Basada en ISO/IEC 27002

Introducción

La información constituye uno de los activos más importantes de cualquier organización. Actualmente, las bases de datos almacenan información crítica relacionada con clientes, proveedores, empleados, expedientes académicos, historiales médicos, transacciones financieras y otros datos estratégicos cuyo valor exige mecanismos adecuados de protección.

El Administrador de Bases de Datos (DBA) tiene la responsabilidad de garantizar que la información permanezca disponible cuando sea requerida, protegida contra accesos no autorizados y libre de modificaciones indebidas. Para lograr este objetivo existen diversos estándares y marcos de referencia internacionales que orientan la implementación de controles de seguridad y la gestión del riesgo.

Entre ellos destaca la familia de normas **ISO/IEC 27000**, particularmente la norma **ISO/IEC 27002**, que proporciona un conjunto de controles para la protección de la información y la reducción de los riesgos asociados a su administración.

Sin embargo, la existencia de controles documentados no garantiza que una organización esté protegida. Es necesario evaluar periódicamente el grado de implementación de dichos controles, determinar su nivel de madurez y estimar la exposición al riesgo que enfrenta la organización respecto a la **Confidencialidad, Integridad y Disponibilidad (CID)** de la información.

Actualmente muchas organizaciones realizan estas evaluaciones mediante documentos impresos o hojas electrónicas, lo que dificulta la consolidación de resultados, el seguimiento histórico, la generación de indicadores y la toma de decisiones.

Con el propósito de modernizar este proceso, una empresa consultora especializada en auditoría y seguridad informática ha decidido desarrollar una aplicación web que automatice la evaluación de los controles de seguridad relacionados con la administración de bases de datos.

Su equipo de trabajo ha sido contratado para diseñar e implementar esta solución.

Situación del Problema

La empresa consultora realiza auditorías de seguridad en organizaciones públicas y privadas.

En cada auditoría se evalúa el grado de implementación de los controles recomendados por la norma **ISO/IEC 27002** aplicables a la administración de bases de datos.

Actualmente el proceso presenta diversas limitaciones.

Los auditores utilizan formularios impresos para registrar la información obtenida durante las entrevistas y revisiones documentales. Posteriormente trasladan la información a hojas de cálculo donde realizan manualmente los cálculos necesarios para estimar el nivel de cumplimiento de los controles y la exposición al riesgo.

Este procedimiento consume una gran cantidad de tiempo, aumenta la posibilidad de errores humanos, dificulta la comparación entre auditorías realizadas en diferentes períodos y limita la generación de información útil para la toma de decisiones.

La empresa desea reemplazar este procedimiento por una aplicación web que permita administrar el cuestionario, registrar las respuestas, calcular automáticamente los resultados obtenidos y generar indicadores que apoyen el análisis de riesgos.

Objetivo del Proyecto

Diseñar e implementar una aplicación web que permita evaluar el nivel de implementación y madurez de los controles de seguridad relacionados con la administración de bases de datos, calcular la exposición al riesgo de **Confidencialidad, Integridad y Disponibilidad** y generar reportes ejecutivos que apoyen la toma de decisiones.

Alcance

La aplicación deberá permitir administrar organizaciones, ejecutar auditorías, almacenar los resultados obtenidos y generar reportes e indicadores relacionados con la gestión del riesgo.

El sistema estará orientado exclusivamente a la evaluación de controles asociados con la administración de bases de datos.

Modelo Conceptual

La solución deberá integrar los siguientes conceptos:

- ISO/IEC 27002.
- Gestión del riesgo.
- Administración de Bases de Datos.
- Controles de seguridad.
- Cuestionarios de auditoría.
- Nivel de madurez de los controles.
- Confidencialidad.
- Integridad.
- Disponibilidad.
- Exposición al riesgo.
- Indicadores.
- Mapas de calor.

Requerimientos Funcionales

La aplicación deberá permitir administrar la información de las organizaciones que serán evaluadas.

Como mínimo deberá registrar:

- Organización.
- Área evaluada.
- Auditor.
- Administrador de Bases de Datos.
- Fecha de la auditoría.
- Usuarios del sistema.

La aplicación deberá administrar los controles de seguridad derivados de la norma ISO/IEC 27002.

Para cada control deberá registrarse como mínimo:

- Código del control.
- Nombre del control.
- Dominio de la norma.

- Objetivo del control.
- Descripción.
- Peso o importancia del control.
- Relación con la Confidencialidad.
- Relación con la Integridad.
- Relación con la Disponibilidad.

Cada control estará conformado por una o varias preguntas.

Cada pregunta deberá permitir responder:

- Sí.
- No.
- No aplica.

Asimismo deberá permitir registrar observaciones, comentarios y evidencias encontradas durante la auditoría.

Cada control deberá calificarse mediante un **nivel de madurez**, el cual representará el grado de implementación observado durante la auditoría.

La aplicación deberá permitir crear nuevas evaluaciones, guardar evaluaciones parcialmente realizadas y continuar posteriormente con el proceso de auditoría.

Al finalizar la evaluación, el sistema deberá calcular automáticamente como mínimo:

- Nivel de cumplimiento de cada control.
- Nivel de madurez de cada control.
- Nivel de cumplimiento por dominio.
- Exposición al riesgo de Confidencialidad.
- Exposición al riesgo de Integridad.
- Exposición al riesgo de Disponibilidad.
- Índice general de exposición al riesgo.

El sistema deberá generar reportes e indicadores que permitan visualizar los resultados obtenidos.

Como mínimo deberán generarse:

- Resultados generales de la auditoría.
- Resultados por dominio.
- Resultados por control.
- Controles con menor nivel de madurez.

- Controles con mayor exposición al riesgo.
- Indicadores estadísticos.
- Gráficos.
- Mapas de calor.
- Reporte ejecutivo de resultados.

Requerimientos No Funcionales

La solución deberá implementarse como una aplicación web.

Cada equipo podrá seleccionar libremente el lenguaje de programación, el gestor de bases de datos, el framework y las tecnologías que considere más apropiadas para el desarrollo del proyecto.

La aplicación deberá presentar una interfaz amigable e intuitiva.

Toda la información deberá almacenarse en una base de datos relacional.

La aplicación deberá validar los datos ingresados por el usuario.

Deberá implementarse autenticación de usuarios y manejo de sesiones.

El diseño deberá adaptarse correctamente a diferentes tamaños de pantalla.

El código fuente deberá organizarse siguiendo buenas prácticas de desarrollo de software.

Aspectos Metodológicos

Cada grupo deberá investigar previamente los siguientes temas:

- Familia de normas ISO/IEC 27000.
- Norma ISO/IEC 27002.
- Gestión del riesgo.
- Confidencialidad.
- Integridad.
- Disponibilidad.
- Administración de Bases de Datos.
- Controles internos.
- Auditoría de Tecnologías de Información.

Cada grupo deberá seleccionar los controles de la norma ISO/IEC 27002 que considere aplicables a la administración de bases de datos.

A partir de dichos controles deberá diseñar su propio instrumento de evaluación.

Cada control deberá transformarse en una o varias preguntas que permitan determinar el grado de implementación del control dentro de una organización.

Cada grupo deberá definir y justificar el peso o importancia de cada control.

Cada grupo deberá determinar cómo afecta cada control a la Confidencialidad, Integridad y Disponibilidad de la información.

Nivel de Madurez de los Controles

Cada control evaluado deberá calificarse según el **grado de implementación observado durante la auditoría**.

El objetivo de esta evaluación es determinar qué tan desarrollado, formalizado y gestionado se encuentra cada control dentro de la organización.

Para todos los proyectos deberá utilizarse la siguiente escala de madurez:

Nivel Descripción

- 0** El control no existe. No hay evidencia de su implementación.
- 1** El control existe de manera informal o es aplicado ocasionalmente, sin procedimientos definidos.
- 2** El control se aplica parcialmente y existen algunas prácticas documentadas, aunque no de forma consistente.
- 3** El control se encuentra documentado, definido e implementado en la mayor parte de los procesos.
- 4** El control se encuentra completamente implementado, es supervisado periódicamente y existen evidencias de su cumplimiento.
- 5** El control se encuentra completamente implementado, es medido, evaluado continuamente y forma parte de un proceso de mejora continua.

Cada grupo deberá diseñar una metodología que permita determinar el nivel de madurez de cada control considerando las respuestas obtenidas en el cuestionario.

La metodología utilizada deberá explicarse y justificarse técnicamente dentro de la documentación del proyecto.

A partir del nivel de madurez obtenido para cada control, cada grupo deberá diseñar e implementar una metodología que permita estimar la exposición al riesgo asociado a la **Confidencialidad, Integridad y Disponibilidad** de la información.

La metodología de cálculo será propuesta por cada equipo y deberá estar debidamente fundamentada.

No existe una única metodología correcta para calcular el riesgo.

Cada equipo deberá investigar, proponer y justificar su propio modelo de evaluación.

Se valorará especialmente la consistencia entre:

- Los controles seleccionados.
- El cuestionario diseñado.
- La escala de madurez utilizada.
- La metodología de cálculo del riesgo.
- Los indicadores generados.
- La interpretación de los resultados.

La originalidad y la solidez técnica de la propuesta formarán parte de la evaluación del proyecto.

Entregables

Cada grupo deberá entregar:

1. Documento de análisis del problema.
2. Marco teórico.
3. Documento de diseño de la solución.
4. Justificación de los controles seleccionados de la norma ISO/IEC 27002.
5. Diseño del instrumento de evaluación.
6. Justificación de la metodología utilizada para calcular el nivel de madurez.
7. Justificación de la metodología utilizada para calcular la exposición al riesgo.
8. Modelo Entidad-Relación.
9. Modelo Relacional.
10. Diccionario de datos.
11. Script SQL para la creación de la base de datos.
12. Aplicación web completamente funcional.
13. Manual de usuario.
14. Manual técnico.
15. Presentación del proyecto.
16. Video demostrativo con una duración entre 10 y 15 minutos.

Valor Agregado

Cada equipo deberá incorporar al menos **tres funcionalidades adicionales** no contempladas en este documento.

Estas funcionalidades deberán aportar valor al proceso de auditoría y deberán ser justificadas durante la presentación final.

Criterios de Evaluación

Criterio	Valor
Investigación y marco teórico	10%
Selección y justificación de los controles ISO/IEC 27002	10%
Diseño del instrumento de evaluación	15%
Diseño y justificación del modelo de madurez	10%
Diseño y justificación del modelo de cálculo del riesgo	15%
Modelo de datos y base de datos	10%
Desarrollo de la aplicación web	20%
Documentación técnica, presentación y defensa del proyecto	10%
Total	100%

Consideraciones Finales

Este proyecto tiene como propósito integrar los conocimientos adquiridos durante el curso de Administración de Bases de Datos con los principios de seguridad de la información, controles internos y gestión del riesgo.

La aplicación desarrollada deberá ir más allá de un simple formulario electrónico. Se espera que constituya una herramienta capaz de apoyar procesos reales de auditoría, permitiendo evaluar el grado de implementación de los controles definidos por la norma ISO/IEC 27002, estimar el nivel de madurez de dichos controles, identificar la exposición al riesgo sobre la **Confidencialidad, Integridad y Disponibilidad** de la información y generar indicadores que faciliten la toma de decisiones.

Cada equipo tendrá libertad para diseñar su propia metodología de evaluación y su propio modelo para el cálculo del riesgo, siempre que las decisiones adoptadas estén debidamente fundamentadas en la literatura técnica y sean consistentes con los principios de la gestión del riesgo.

El éxito del proyecto no dependerá únicamente del funcionamiento de la aplicación, sino también de la capacidad del equipo para investigar, analizar, justificar y defender técnicamente las decisiones adoptadas durante el diseño de la solución. Se valorará especialmente la calidad metodológica, la coherencia entre los componentes del sistema, la fundamentación técnica y la capacidad para transformar los conceptos estudiados en una herramienta informática que pueda ser utilizada por organizaciones reales para apoyar la gestión de la seguridad de la información en el área de administración de bases de datos.